IqraSec Academy | WAPT Phase 1

Task 4: Web Vulnerabilities – Access Control

Intern name	Maryam Batool
Report title	Task 4: Common Web Vulnerabilities — Authentication & Access Control
Rooms / Labs covered	PortSwigger Web Security Academy — Unprotected admin functionality
Date completed	1 November 2026

1. Lab Name

Unprotected admin functionality (PortSwigger Web Security Academy).

2. Objective

To identify an admin panel that is reachable without any authentication or authorisation check, and use it to perform a privileged action (deleting a user) as an unauthenticated visitor.

3. Vulnerability / Concept

- This is a broken access control issue: the application has an administrative function, but relies on the page simply not being linked from the normal site navigation, instead of actually checking whether the visitor is logged in and is an admin.
- This is sometimes called "security by obscurity" — hiding a URL instead of enforcing access control on it. If the URL is discovered by any means, the function is fully accessible to anyone, authenticated or not.
- A common way such URLs leak is through the site's own robots.txt file. Developers add sensitive paths to robots.txt to stop search engines from indexing them, which ironically publishes the exact path to anyone who looks.

4. Testing Approach

- Opened the lab's shop as a logged-in low-privilege user and confirmed there was no visible link to any admin area; status was Not solved.
- Requested /robots.txt directly, which revealed a Disallow: /administrator-panel entry — a path the site did not want search engines to index, but which was not actually protected.
- Navigated directly to /administrator-panel as the ordinary user and reached a working "Users" admin page listing accounts (wiener, carlos) with Delete links, confirming no authorisation check was enforced on this page.
- Clicked Delete next to the carlos account to confirm the admin action could be carried out. The response confirmed "User deleted successfully!" and the lab status changed to Solved.

5. Evidence / Screenshots

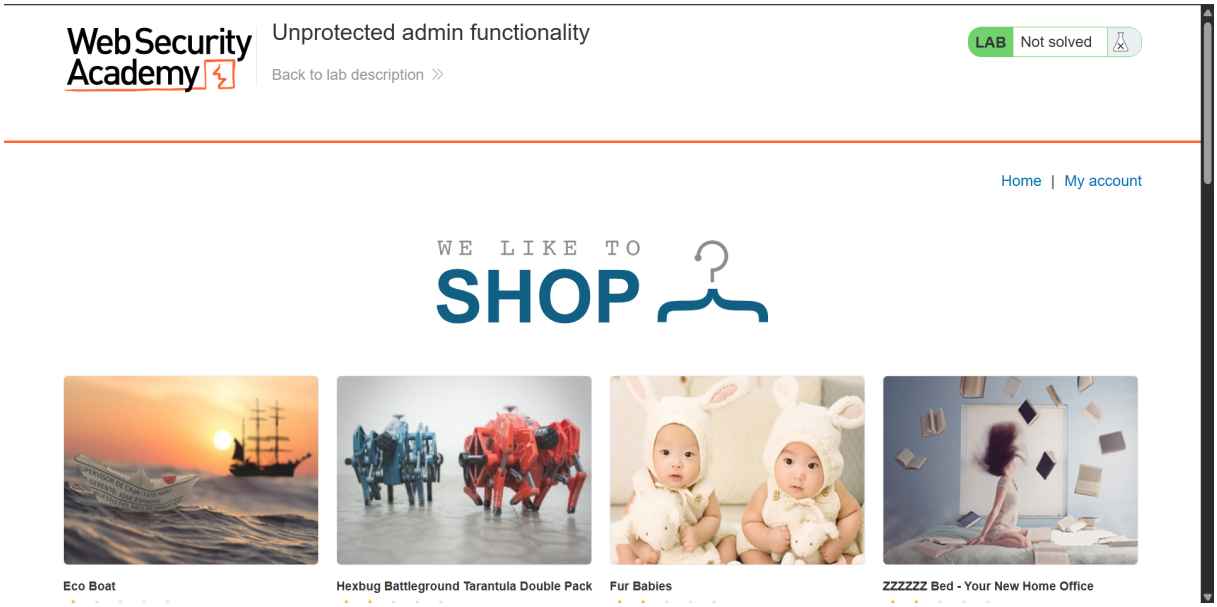


Figure 1: *Lab's shop front page as a logged-in user; no admin link visible, status Not solved.*

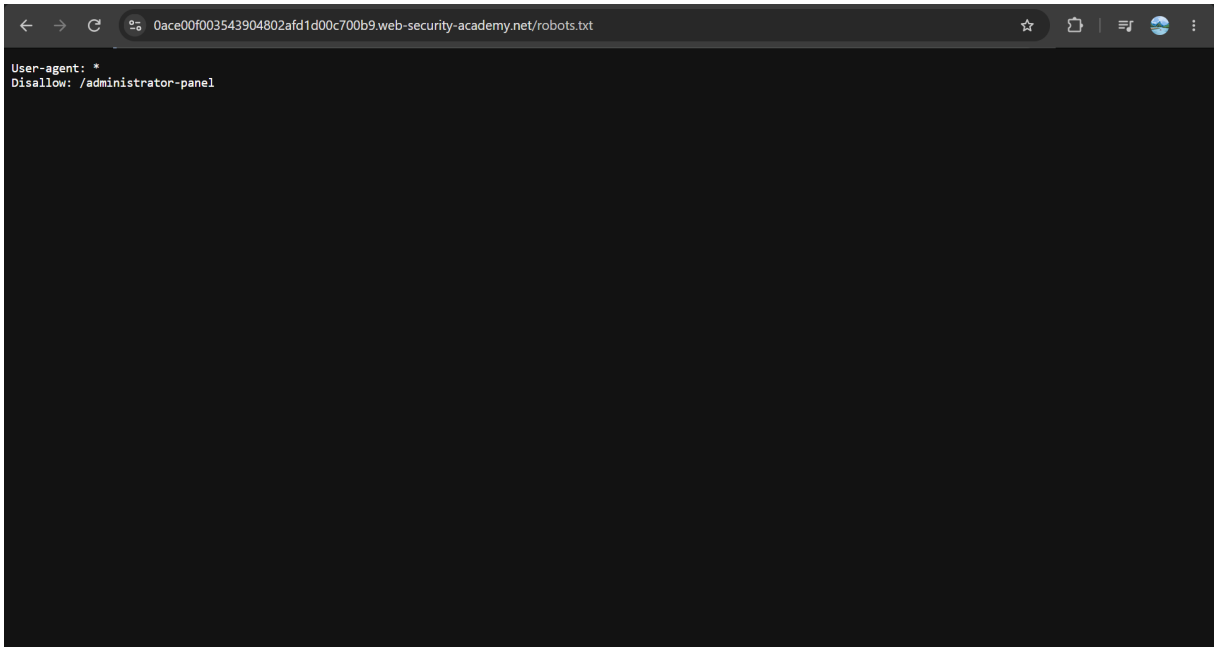


Figure 2: *robots.txt disclosing the hidden admin path: Disallow: /administrator-panel.*

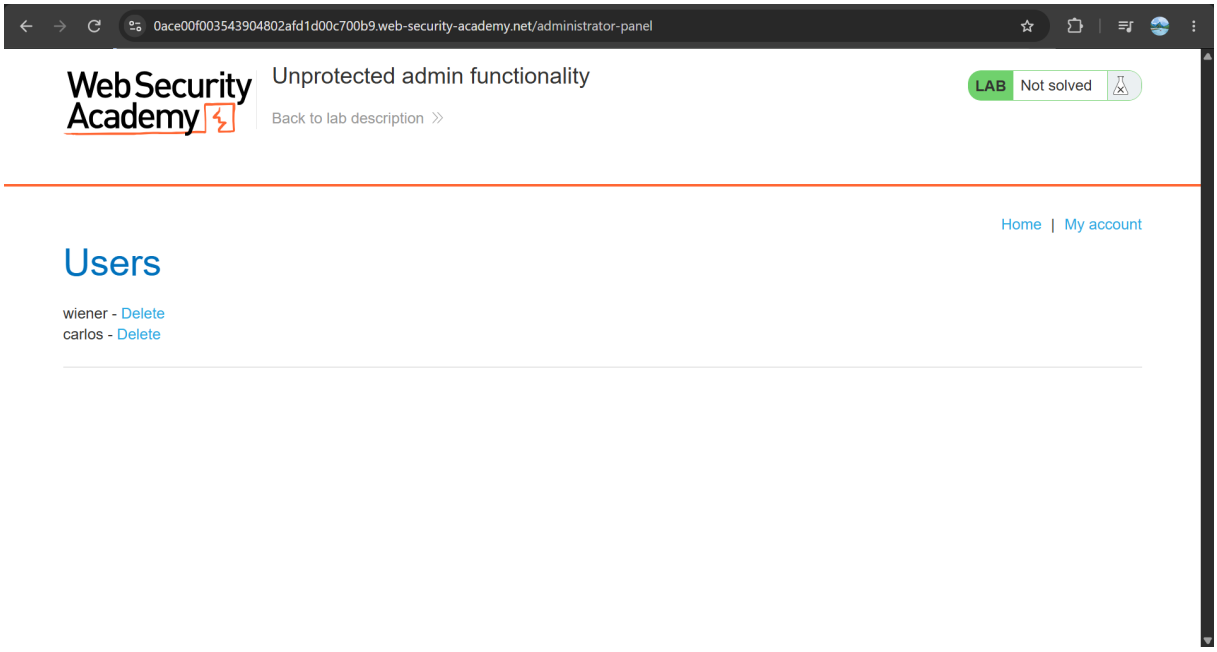


Figure 3: */administrator-panel reached directly with no login/authorisation check; Users list shown with wiener and carlos, each with a Delete option.*

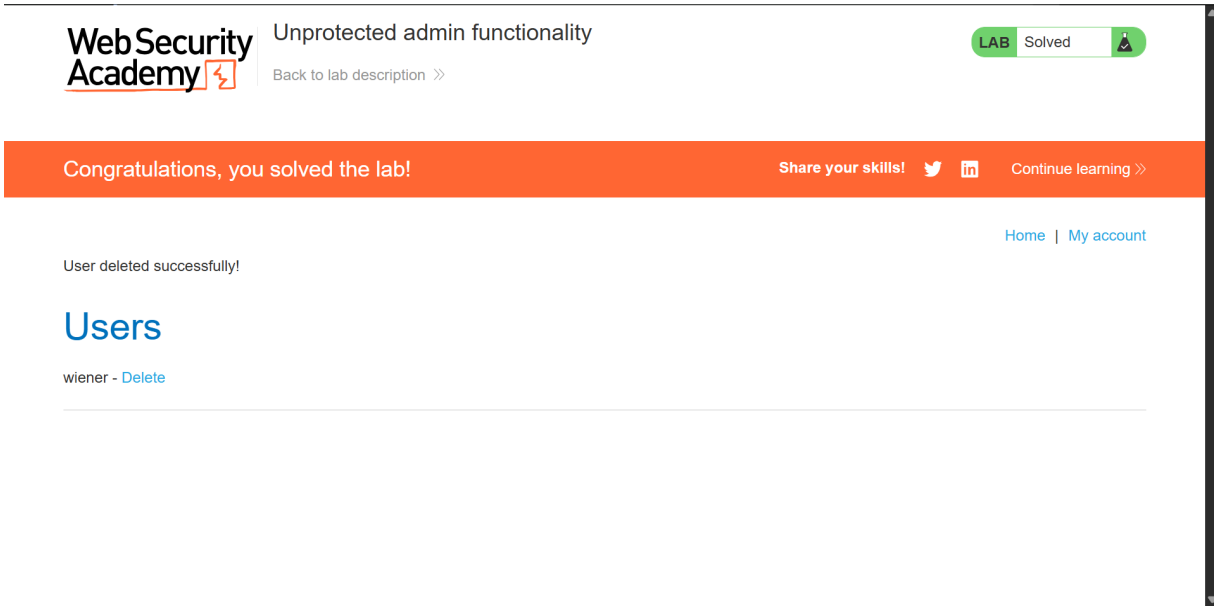


Figure 4: *carlos deleted via the exposed admin panel; 'User deleted successfully!' message shown and lab status now Solved.*

6. Impact

An attacker who finds an unprotected admin path can perform any action the admin panel exposes — here, deleting user accounts — without ever authenticating. Depending on what the panel controls, this class of vulnerability can lead to full account takeover, data loss, or complete compromise of the application if more sensitive admin functions (such as changing roles or site configuration) are exposed the same way.

7. Remediation

- Enforce server-side authentication and authorisation checks on every admin endpoint, not just on the links shown in the UI — never rely on a URL simply not being advertised.

- Do not list sensitive paths in robots.txt; if a path must stay out of search indexes, protect it properly instead (authentication, IP allow-listing, etc.) rather than just asking crawlers not to visit it.
- Apply the principle of least privilege: an admin action should check the current session's role on every request, server-side, before executing.

8. What I Learned

- "Hidden" is not the same as "protected" — an unlinked page is still fully reachable if its URL leaks, and robots.txt is a very common and easy way for that to happen.
- Broken access control doesn't always need a clever payload; sometimes just requesting the right URL directly is enough, which makes it both easy to miss during development and easy to find during testing.
- Admin functionality should always be checked specifically for access control during a pentest, since its impact (user/account management) is usually much higher than a typical user-facing page.

Declaration: I confirm that this report documents my own work and that all screenshots were taken by me during the tasks described.

Name: Maryam Batool Date: 1 November 2026